

# Privacy & Dignity Policy

|                       |                              |                                |                                                              |                                      |
|-----------------------|------------------------------|--------------------------------|--------------------------------------------------------------|--------------------------------------|
| VERSION<br><b>1.0</b> | EFFECTIVE<br>[ ] [ ] [ ] [ ] | NEXT REVIEW<br>[ ] [ ] [ ] [ ] | OWNER<br><b>Principal / Key<br/>Management<br/>Personnel</b> | APPROVED BY<br><b>Governing body</b> |
|-----------------------|------------------------------|--------------------------------|--------------------------------------------------------------|--------------------------------------|

## PURPOSE AT A GLANCE

[ ] every client with dignity and respect and protects the personal information it holds. This policy explains what information we collect, why, how we store and secure it, who we share it with, and how clients can access or correct their information or raise a privacy concern. It gives effect to the *Privacy and Dignity and Information Management* NDIS Practice Standards and the Australian Privacy Principles.

## 1. Purpose and scope

This policy supports [ ] the Privacy and Dignity and Information Management NDIS Practice Standards. It applies to all services and supports delivered by [ ] all employees, contractors and volunteers (**Workers**), who must take full responsibility for understanding and following it. It should be read alongside the related documents in section 12 and the corresponding procedures in the Policy Register.

## 2. Our commitments

[ ] committed to ensuring that:

- consistent processes respect and protect the personal privacy and dignity of each participant;
- each participant's information is identifiable, accurately recorded, current, confidential, easily accessible to the participant, and appropriately used by relevant Workers;
- each participant understands and agrees to what personal information is collected and why, including any audio or visual recording;
- each participant's consent is obtained to collect, use, retain or disclose their information, and they are told when information could be disclosed without consent if required or authorised by law;
- each participant is informed how their information is stored and used, and how and when they can access or correct it or withdraw or amend consent; and
- an information management system is maintained that is proportionate to the size and scale of the organisation and records information accurately and promptly, with appropriate access, transfer, storage, security, retention and disposal processes.

## 3. Communicating this policy

So that clients understand this policy in the language, mode of communication and terms they are most likely to understand, [ ] be respectful, clear and honest communication; consistently respect privacy and confidentiality; promote understanding through active listening, plain language and encouraging questions; identify and make reasonable efforts to address communication barriers, including providing

information about interpreter, legal and advocacy services; and work with interpreters, communication specialists and advocacy services to support participation, informed choice and control.

#### 4. What personal information we collect

---

The personal information [redacted] ts from a client includes their:

- name, address, telephone and email contact details;
- gender, date of birth and marital status, and information about their disability and support needs;
- health and medical information;
- identifiers used by government agencies or other organisations;
- financial and billing information, including what services they are funded to receive under the NDIS or otherwise;
- records of interactions, such as system notes and records of conversations with Workers; and
- information about the services [redacted] les and how they are delivered.

Typically [redacted] not collect personal information in the form of recorded audio or visual material.

#### 5. Sensitive information and dignity

---

[redacted] collects sensitive information where it is reasonably necessary for its functions or activities and either the individual has consented or [redacted] uired or authorised by law. For example, to provide services or respond to enquiries [redacted] eed to collect health and medical information and information about a person's disability and support requirements. [redacted] at clients with dignity and respect and, as far as reasonably practicable, protect the privacy and dignity of each participant and, in particular, their sensitive information.

#### 6. How we collect personal information

---

[redacted] ts personal information when individuals correspond with us (by letter, email or telephone), on hard-copy forms, in person, from referring third parties (such as the NDIA or a support coordinator), at events and forums, and from third-party funding and government agencies.

#### 7. Why we collect, hold, use and disclose personal information

---

The main purposes are to: provide information about our services; answer enquiries and deliver services; administer services and process payments; conduct quality assurance, surveys, research and analysis and resolve complaints; comply with laws and report to funding and government agencies; recruit Workers; evaluate and report on our work; carry out internal functions such as administration, training, accounting, audit and IT; and for any purpose explained at the time of collection, required or authorised by law, or consented to. De-identified data may be used for research, service evaluation, quality assurance and education; a client who does not want their de-identified data used this way can contact [redacted] Where a client has consented to marketing communications, that consent continues until they opt out, which they can do at any time.

## 8. Who we disclose personal information to

[ ] disclose personal information, where appropriate for the purposes above, to: our funding providers; government and regulatory bodies including the NDIA, Services Australia, the Department of Social Services, health departments and the ATO; people acting on the client's behalf (nominated representatives, legal guardians, executors, trustees and legal representatives); police, the NDIS Commission, or courts and tribunals under compulsory notice; financial institutions for payment processing; referees provided by job applicants; and contracted service providers such as IT, invoice processing, marketing and communications, freight and courier services, and external advisers (recruitment advisers, auditors and lawyers).

## 9. How we store, secure and retain personal information

[ ] personal information in hard-copy documents, electronic databases, email contact lists and paper files in locked cabinets; archived paper files may be stored offsite in secure facilities. Security measures include encryption, firewalls and anti-virus software; login and password protection on systems and cloud storage; controlled access to premises; restricting use of personal information to Workers with a legitimate need to know; and training and workplace policies.

[ ] reasonable steps to keep personal information accurate, up to date, complete and relevant; to protect it from misuse, interference, loss and unauthorised access, modification or disclosure; and to destroy or permanently de-identify information no longer needed, subject to legal retention requirements.

When handling personal information, Workers must:

Only access and use personal information for a valid work purpose.

Confirm recipient details before sending emails or faxes.

Store hard copies not in use in a secure cabinet or room; limit removing hard copies from secure sites and secure information when travelling.

Be aware of surroundings and people nearby when discussing or displaying information.

Dispose of unneeded copies securely (secure bins or shredders) and ensure electronic media is sanitised when no longer required.

Only share personal information as set out in this policy and where permitted by law.

**Retention.** Unless the law requires otherwise, all client records and personal information are retained for at least **seven years** after a client ceases to be a client. Record-retention requirements must be met before any personal information is disposed of.

## 10. Privacy incidents and breach reporting

Privacy incidents occur when unauthorised people access, change or destroy personal information — for example a device is lost or stolen, a document is sent to the wrong address, information is disposed of insecurely, or personal information is shared on social media. Incidents can be accidental or deliberate, arise from human error or technical failure, and involve information in any form.

All privacy incidents must be reported to a manager as soon as a Worker becomes aware of them, so their impact can be minimised — the purpose of reporting is minimisation, not punishment. [ ] report all client-related privacy incidents, as applicable, to the relevant health department, the NDIS Commission and the Office of the Australian Information Commissioner within **one business day** of

becoming aware of a possible incident or of an allegation of a potential breach. Each incident is also managed under the Incident Management and Reporting Policy.

## 11. Access and correction

Clients have a legal right to request access to, or correction of, the personal information [redacted] holds about them. [redacted] ask a person to verify their identity before processing a request, to ensure information is properly protected.

## 12. Complaints about privacy

A complaint about how [redacted] collected or handled personal information is managed under the [redacted] Feedback and Complaints Management System. A person may also complain to the Office of the Australian Information Commissioner (oaic.gov.au) or the NDIS Commission.

## 13. Definitions

### Client

A client of [redacted] ng an NDIS participant.

### Personal information

Information or an opinion about an identified or reasonably identifiable individual, whether true or not and whether recorded in a material form or not.

### Sensitive information

A subset of personal information given higher protection — including health and genetic information and information about racial or ethnic origin, political or religious beliefs, association memberships, sexual orientation or practices, criminal record and some biometric information.

### Key Management Personnel (KMP)

[redacted] her key management personnel involved in [redacted] ne to time.

### Principal

### Worker

A permanent, fixed-term or casual member of staff, a contractor or a volunteer engaged by [redacted] ng the Principal.

## 14. Related documents and approval

**Related documents:** Information Management Policy · Privacy Consent Form · Incident Management and Reporting Policy · Feedback and Complaints Policy · Promoting and Protecting Rights · Client Information Booklet · Legislation Register · Policy Register.

**Legislation and rules:** as set out in the Legislation Register, including the Privacy Act 1988 (Cth) and the Australian Privacy Principles, and the NDIS Act 2013 and associated Rules.

If any part of this policy is inconsistent with applicable law, it is taken to be amended only to the extent needed to comply.

|                       |                        |
|-----------------------|------------------------|
| Approved by           | <div><div></div></div> |
| Approval date         | <div><div></div></div> |
| Next scheduled review | <div><div></div></div> |
| Version               | 1.0                    |

SAMPLE · NOT LICENSED